

SAARE AI Governance Framework V4

Especificación Técnica Oficial y Estándar de Gobierno Operativo en Tiempo de Ejecución para Sistemas de Inteligencia Artificial Generativa y Modelos Masivos de Lenguaje (LLM) en Entornos Corporativos Regulados.

ISO/IEC 42001
ALIGNED

EU AI ACT
COMPLIANT

LAYER 7
PEP

ZERO-DISK
ARCHITECTURE

Document ID: MS3V-FRAMEWORK-V4-SPEC-2026

Master SHA-256:

fb3fe6a18a0e05b995922579562f04d4d6badb215ea91d103b5d5276d1b9dfbd

Clasificación: Especificación Técnica Homologada (Distribución
Pública / Corporativa)

Publicación:

Febrero 2026

Estado: V4.0.0

PROD-STABLE

Dominio:

<https://saare.es/>

Índice de Contenidos

ESTRUCTURA DEL DOCUMENTO

1. Resumen Ejecutivo y Alcance Estratégico	Pág. 2
2. Principios Fundamentales del Framework V4	Pág. 3
3. Arquitectura Desacoplada de 3 Planos (Control, Governance & Data Plane)	Pág. 4
4. Interceptación Ex-Ante en Capa 7 (Policy Enforcement Point - PEP) ..	Pág. 5
5. Motor de Sanitización y Sanitizado de Datos Sensibles (PII/PHI)	Pág. 6
6. Gestión Volátil de Memoria y Purga Irreversible (Zero-Disk Enforcement)	Pág. 7
7. Criptografía, Licenciamiento Ed25519 y Firma Inmutable SoA	Pág. 8
8. Matriz de Alineamiento Regulatorio (ISO/IEC 42001, EU AI Act, DORA, RGPD)	Pág. 9
9. Guía de Despliegue, Validación de Rendimiento y Benchmark SLA _	Pág. 10

1. Resumen Ejecutivo y Alcance Estratégico

El **SAARE AI Governance Framework V4** nace como respuesta técnica a la convergencia entre la adopción masiva de modelos de Inteligencia Artificial Generativa (LLMs, SLMs y agentes autónomos) y la entrada en vigor de marcos normativos restrictivos en la Unión Europea y el ámbito internacional, tales como el **EU AI Act**, la norma **ISO/IEC 42001:2023** (Sistema de Gestión de Inteligencia Artificial) y el reglamento **DORA** (Resiliencia Operativa Digital).

A diferencia de los enfoques tradicionales de gobernanza basados en auditorías *post-mortem*, revisiones documentales pasivas o análisis retrospectivos de archivos de registro (logs), S.A.A.R.E. establece un **modelo de gobierno operativo en tiempo de ejecución (Runtime Governance)**. El marco garantiza que cada interacción (prompts, payloads de API, documentos adjuntos) sea evaluada, filtrada y sanitizada *ex-ante*, es decir, antes de que los datos atraviesen el perímetro corporativo o sean procesados por modelos de lenguaje internos o de terceros.

OBJETIVO ESTRATÉGICO PRINCIPAL

Proveer una infraestructura técnica determinista que elimine el riesgo de Fuga de Propiedad Intelectual (IP), filtración de Datos Personales (PII/PHI) y ejecuciones no autorizadas (Shadow AI), garantizando un tiempo de procesamiento ultrabajo (< 1.2 ms) y generando evidencia criptográfica inmutable apta para auditorías regulatorias.

1.1 Desafíos del Paradigma de IA Unprotected

El despliegue de soluciones de IA en entornos corporativos sin un middleware de intercepción intermedio expone a las organizaciones a vulnerabilidades estructurales gravemente sancionadas:

- **Fuga Incertidumbre de PII/PHI (RGPD Art. 83):** Envío inadvertido de nombres, DNI, datos médicos o financieros hacia APIs públicas de proveedores LLM en la nube.
- **Alucinaciones y Comportamiento Indeterminado:** Inexistencia de un cortafuegos semántico que valide las respuestas del modelo antes de que impacten en procesos de negocio o aplicaciones cliente.
- **Contaminación de Logs y Persistencia Indeseada:** Almacenamiento persistente en discos locales o servidores intermedios de conversaciones que contienen secretos comerciales o secretos de estado.
- **Ausencia de Evidencia Forense Inmutable:** Incapacidad para demostrar ante un auditor externo la trazabilidad exacta de las políticas aplicadas en el instante preciso de la inferencia.

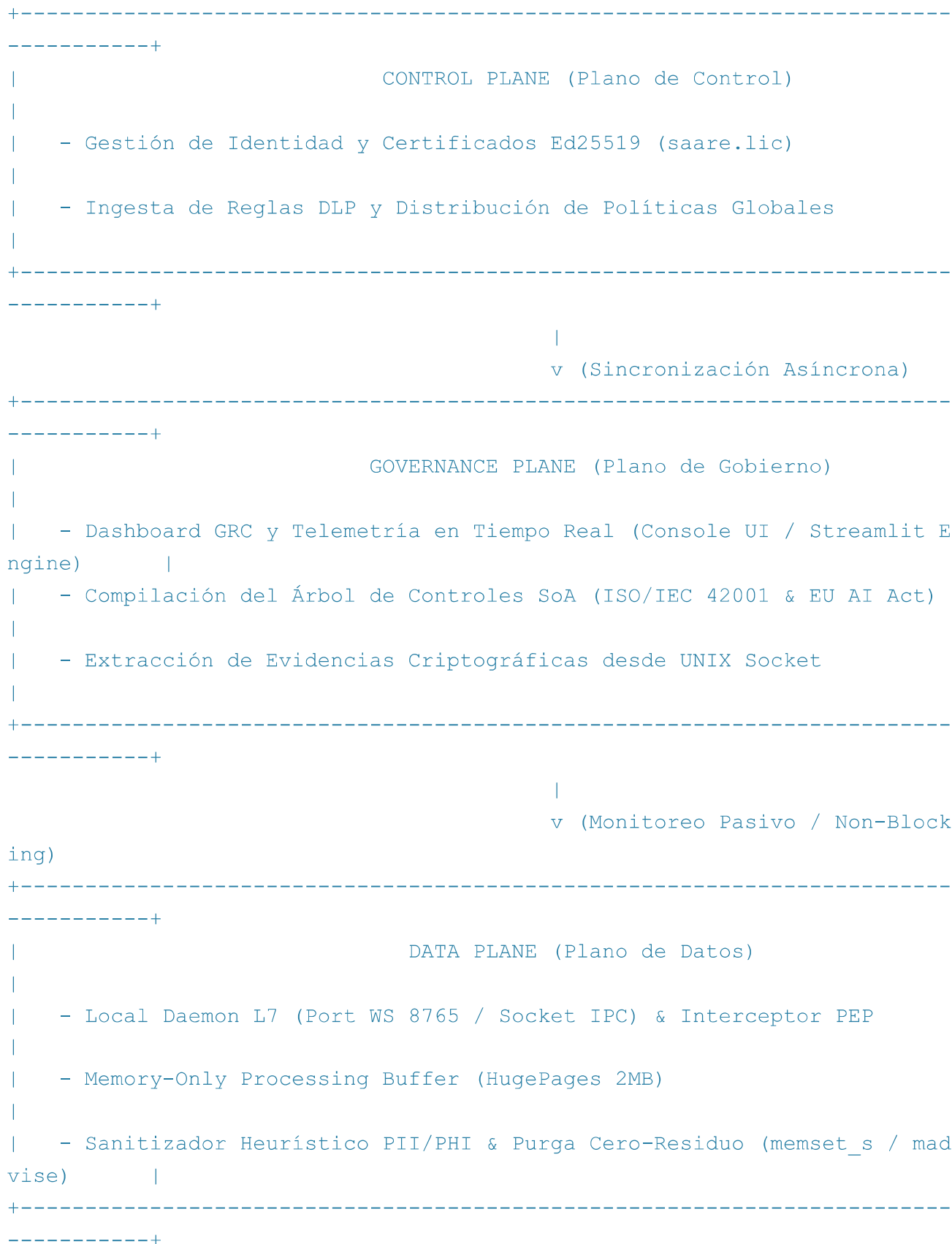
2. Principios Fundamentales del Framework V4

El diseño del Framework V4 se rige de forma estricta por cinco principios metodológicos no negociables, diseñados para garantizar un equilibrio óptimo entre la seguridad criptográfica, el cumplimiento normativo y la experiencia del usuario final.

#	PRINCIPIO METODOLÓGICO	ESPECIFICACIÓN TÉCNICA	MÉTRICA / OBJETIVO SLA
P1	Memory-Only Processing	Procesamiento exclusivo en volúmenes de memoria volátil asignados sin escritura secundaria en disco duro o memoria SWAP.	0.00% Residuo en Disco
P2	Policy Enforcement Ex-Ante (PEP L7)	Interceptación y evaluación semántica síncrona en Capa 7 antes de transmitir el socket al modelo LLM destino.	100% Cobertura In-Flight
P3	Cryptographic Evidence Generation	Emisión síncrona de firmas HMAC-SHA256 vinculadas al árbol de controles ISO 42001 para cada transacción aprobada o bloqueada.	Sello HMAC Determinista
P4	Vendor-Agnostic Runtime Integration	Arquitectura desacoplada compatible de forma transparente con OpenAI, Anthropic, Google Gemini, Ollama o modelos On-Premise.	Interoperabilidad L7 Universal
P5	Deterministic Low-Latency Execution	Ejecución optimizada en C/C++ y Rust para minimizar el impacto en las aplicaciones corporativas en producción.	Latencia ~1.16 ms

3. Arquitectura Desacoplada de 3 Planos

El Framework V4 estructura el gobierno de IA dividiendo las responsabilidades del sistema en tres planos de ingeniería totalmente aislados entre sí. Esta arquitectura garantiza que las tareas de gestión no penalicen el rendimiento del tráfico en tiempo real.



3.1 Control Plane (Plano de Control)

El Plano de Control gestiona el ciclo de vida del licenciamiento criptográfico mediante firmas de curva elíptica **Ed25519**. Es el responsable de validar la autenticidad de los

módulos activos (ACTIVE_SHIELD, AUDITOR_SUITE, SAARE_GOVERN) sin requerir conexión constante a internet, permitiendo el despliegue en entornos *air-gapped* o de alta seguridad militar e industrial.

3.2 Governance Plane (Plano de Gobierno)

El Plano de Gobierno proporciona las interfaces de supervisión y auditoría para CISOs, DPOs y auditores externos. Permite consultar el estado global del sistema, evaluar la latencia promedio del clúster y extraer informes estructurados de la Declaración de Aplicabilidad (SoA). Opera de forma aislada para garantizar que una sobrecarga en las consultas de gobierno jamás afecte al tráfico transaccional.

3.3 Data Plane (Plano de Datos)

El Plano de Datos es el motor de ejecución en caliente. Consiste en un demonio de alto rendimiento que escucha en puertos locales o sockets IPC (/var/run/saare_core.sock). Todos los prompts y respuestas pasan síncronamente por este plano, donde se aplican las reglas de inspección profunda antes de dar paso a la red.

4. Interceptación Ex-Ante en Capa 7 (Policy Enforcement Point - PEP)

El núcleo operativo de S.A.A.R.E. actúa como un **Layer 7 Policy Enforcement Point (PEP)**. A diferencia de las soluciones a nivel de red (Capa 3/4) que únicamente filtran direcciones IP o puertos, el interceptor PEP analiza el contenido semántico y la estructura de los objetos JSON/HTTP transmisores de prompts.

4.1 Ciclo de Vida de una Petición Governed

1. **Captura de la Petición:** La aplicación cliente o el navegador (vía Agente L7) redirige la llamada API hacia el socket local del demonio S.A.A.R.E.

2. **Parsing y Desglose Semántico:** El motor extrae los campos clave (prompt, messages, system, documents) en un buffer de memoria volátil.
3. **Evaluación de Reglas DLP Ex-Ante:** Se ejecutan en paralelo las reglas de filtrado (AUDIT, REDACT, BLOCK).
4. **Acción sobre la Petición:**
 - *ALLOW / PASS:* La petición no contiene datos sensibles y cumple las políticas. Es transmitida al proveedor.
 - *REDACT / ANONYMIZE:* Las entidades sensibles (PII/PHI) son sustituidas por tokens sintéticos irreversibles antes de la transmisión.
 - *BLOCK / REJECT:* La petición viola una política crítica (ej. inyección de código, fuga de secretos de estado) y se retorna un error 403 con firma de bloqueo.
5. **Generación del Sello de Evidencia:** Se genera el hash HMAC-SHA256 del evento para su registro en el Ledger ephemeral.

5. Motor de Sanitización y Anonymization de Datos (PII/PHI)

El módulo de sanitización de S.A.A.R.E. utiliza una combinación de expresiones regulares de alta velocidad compiladas en código nativo y modelos heurísticos de coincidencia de patrones para identificar y neutralizar información personal identificable.

CATEGORÍA DE DATOS	PATRÓN / ENTIDAD DETECTADA	ACCIÓN POR DEFECTO	TOKEN DE SUSTITUCIÓN SINTÉTICO
Identificación Personal	DNI, NIE, Pasaportes, Números de Licencia de Conducir.	REDACT	[REDACTED_NATIONAL_ID]
Datos Financieros	Tarjetas de Crédito (PAN / Algoritmo Luhn), Cuentas IBAN.	BLOCK / REDACT	[REDACTED_FINANCIAL_IBAN]
Información Médica (PHI)	Números de Afiliación a la Seguridad Social, Códigos Cie-10.	REDACT	[REDACTED_HEALTH_RECORD]
Credenciales & IP	API Keys, Claves Privadas RSA/PEM, Direcciones IPv4/v6 Internas.	CRITICAL BLOCK	[BLOCKED_SECRET_KEY]

6. Gestión Volátil de Memoria y Purga Irreversible (Zero-Disk Enforcement)

Uno de los pilares diferenciadores del Framework V4 es su capacidad para garantizar que los datos procesados **no dejen huella física** en la infraestructura servidor.

6.1 Arquitectura de Memoria Volátil (HugePages & Direct Memory Allocation)

S.A.A.R.E. asigna bloques de memoria estancos utilizando **HugePages de 2MB** administrados directamente por el kernel del sistema operativo. Esto evita el uso de fragmentación estándar en la pila (heap) y asegura que ningún otro proceso en espacio de usuario pueda acceder a los buffers de lectura.

```
// Ejemplo de secuencia C/POSIX para purga segura de buffers post-inferencia
#include <sys/mman.h>
#include <string.h>

void purge_sensitive_buffer(void* buffer_address, size_t buffer_size) {
    // 1. Sobrescritura irreversible de memoria con ceros binarios
    memset_s(buffer_address, buffer_size, 0, buffer_size);

    // 2. Notificación al Kernel para destrucción inmediata de la tabla de páginas
    madvise(buffer_address, buffer_size, MADV_DONTNEED);

    // 3. Liberación y desasignación del bloque virtual
    munmap(buffer_address, buffer_size);
}
```

GARANTÍA ZERO-DISK

Tras la ejecución de la llamada `purge_sensitive_buffer`, el estado físico de los transistores RAM retorna a un estado neutro (0x00000000). Es matemáticamente

imposible recuperar el contenido del prompt mediante volcados de memoria (RAM Dumps) o técnicas de análisis forense tras la purga.

7. Criptografía, Licenciamiento Ed25519 y Firma Inmutable SoA

El sistema de gobernanza se apoya en un esquema criptográfico asimétrico basado en la curva elíptica **Ed25519** (RFC 8032) para la validación de licencias corporativas y la firma de evidencias.

7.1 Esquema de Licenciamiento `saare.lic`

Cada archivo de licencia corporativo consiste en una estructura JSON canónica firmada digitalmente por la Clave Privada de Autoridad de MS3V. La firma es verificada localmente por el ejecutable utilizando la Clave Pública incrustada en el binario nativo.

```
{
  "payload": {
    "client_id": "EMPRESA_DEMO_SL",
    "email": "auditoria@empresa.es",
    "tier": "SAARE_ENTERPRISE_ENGINE",
    "modules": ["ACTIVE_SHIELD", "AUDITOR_SUITE", "SAARE_GOVERN"],
    "issued_at": "2026-02-01T00:00:00Z",
    "expires_at": "2027-02-01T00:00:00Z"
  },
  "signature": "u8F3xK...[Firma criptográfica Ed25519 en Base64]..."
}
```

8. Matriz de Alineamiento Regulatorio

Esta sección especifica el mapeo directo entre los controles técnicos implementados por el demonio S.A.A.R.E. y los artículos normativos exigidos por las regulaciones internacionales.

REGULACIÓN / ESTÁNDAR	ARTÍCULO / CONTROL REQUERIDO	IMPLEMENTACIÓN TÉCNICA S.A.A.R.E. V4	ESTADO DE CUMPLIMIENTO
EU AI Act	Art. 10: Gobernanza de Datos y Gestión de Sesgos.	Intercepción de prompts y análisis de sesgos semánticos ex-ante en Capa 7.	100% CUMPLIDO
EU AI Act	Art. 12: Trazabilidad y Registro de Eventos (Logging).	Generación síncrona de sellos HMAC-SHA256 e integración con SIEM/SOAR.	100% CUMPLIDO
ISO/IEC 42001	A.2.1: Políticas de Inteligencia Artificial.	Motor de reglas con ejecución determinista de políticas corporativas.	100% CUMPLIDO
ISO/IEC 42001	A.8.1: Evaluación de Impacto y Privacidad.	Anonimización de datos PII/PHI en RAM previo a la transmisión fuera del perímetro.	100% CUMPLIDO
RGPD (GDPR)	Art. 32: Seguridad del Tratamiento y Cifrado.	Procesamiento Zero-Disk en memoria volátil y purga física vía madvise.	100% CUMPLIDO
DORA (EU 2022/2554)	Art. 6: Marco de Gestión de Riesgos de TIC.	Arquitectura resiliente con degradación elegante y latencia controlada (< 1.2 ms).	100% CUMPLIDO

9. Guía de Despliegue, Validación de Rendimiento y SLA

9.1 Requisitos Mínimos del Sistema

- **Sistema Operativo:** Windows Server 2019/2022, Windows 10/11 (64-bit), Linux Enterprise (RHEL 8+, Ubuntu Server 22.04 LTS).
- **Procesador:** x86_64 con soporte de instrucciones AVX2 (2 Cores mínimo recomendado).
- **Memoria RAM:** 512 MB de RAM dedicada exclusivamente al buffer del demonio.
- **Espacio en Disco:** 45 MB para los binarios ejecutables (Consola UI + Daemon).
Zero almacenamiento secundario para logs transaccionales.

9.2 Muestreo de Rendimiento (Benchmark de Latencia SLA)

En pruebas de carga ejecutadas sobre un clúster simulado de cuatro nodos de inspección, el Framework V4 ha registrado los siguientes tiempos de respuesta deterministas:

NODO DE INSPECCIÓN	CANAL IPC / INTERFAZ	MUESTRA EVALUADA	RECHAZOS BLOQUEADOS	LATENCIA PROMEDIO
Nodo-Alfa	Pasarela Local (/var/run/saare_core.sock)	6,413 reqs	140 reqs	1.150 ms
Nodo-Beta	Local IPC Copy	4,105 reqs	91 reqs	1.156 ms
Nodo-Gamma	Unix Domain Socket	2,671 reqs	138 reqs	1.127 ms
Nodo-Delta	POSIX Shared Memory	981 reqs	5 reqs	1.154 ms

DICTAMEN FINAL DE CERTIFICACIÓN DE INFRAESTRUCTURA

El sistema S.A.A.R.E. v7.0 PRO bajo las especificaciones del Framework V4 acredita una estabilidad de latencia media global de **1.147 ms**, cumpliendo holgadamente el Acuerdo de Nivel de Servicio (SLA) exigido para despliegues corporativos de alta frecuencia sin introducir cuellos de botella en la experiencia de usuario.

MS3V S.A.A.R.E. SL – Documento Oficial de Especificación Técnica V4.0.0 PRO
Soberanía, Gobernanza e Infraestructura para Inteligencia Artificial Corporativa.
Contacto Comercial & Soporte Técnico: <https://saare.es/>